

Department of Computer Science & Engineering
Uttara University

MIS0611403 - System Auditing & Maintenance

Conducted By
Sumaya Akter
Lecturer, Department of CSE, Uttara University

Security Part I: Auditing Operating Systems and Networks

Operating System

Operating System : An operating system is the computer's control program that manages and allows shared access to system resources such as processors, memory, databases, and devices. The integrity of the operating system is crucial because if it is compromised, security and control mechanisms within all applications—especially accounting systems—can be bypassed, potentially causing widespread damage across the entire computer system.

Operating System Objectives

Main Tasks performed by an Operating system (OS):

- The OS translates high-level languages, such as COBOL, C++, BASIC, and SQL, into the machine-level language that the computer can execute. The language translator modules of the operating system are called **compilers and interpreters.**
- The operating system allocates computer resources to users, workgroups, and applications.
- The operating system manages the tasks of job scheduling and multiprogramming

Operating System Objectives

To perform those main tasks consistently and reliably, the operating system must achieve five fundamental control objectives:

1. The operating system must protect itself from users. User applications must not be able to gain control of, or damage in any way, the operating system.

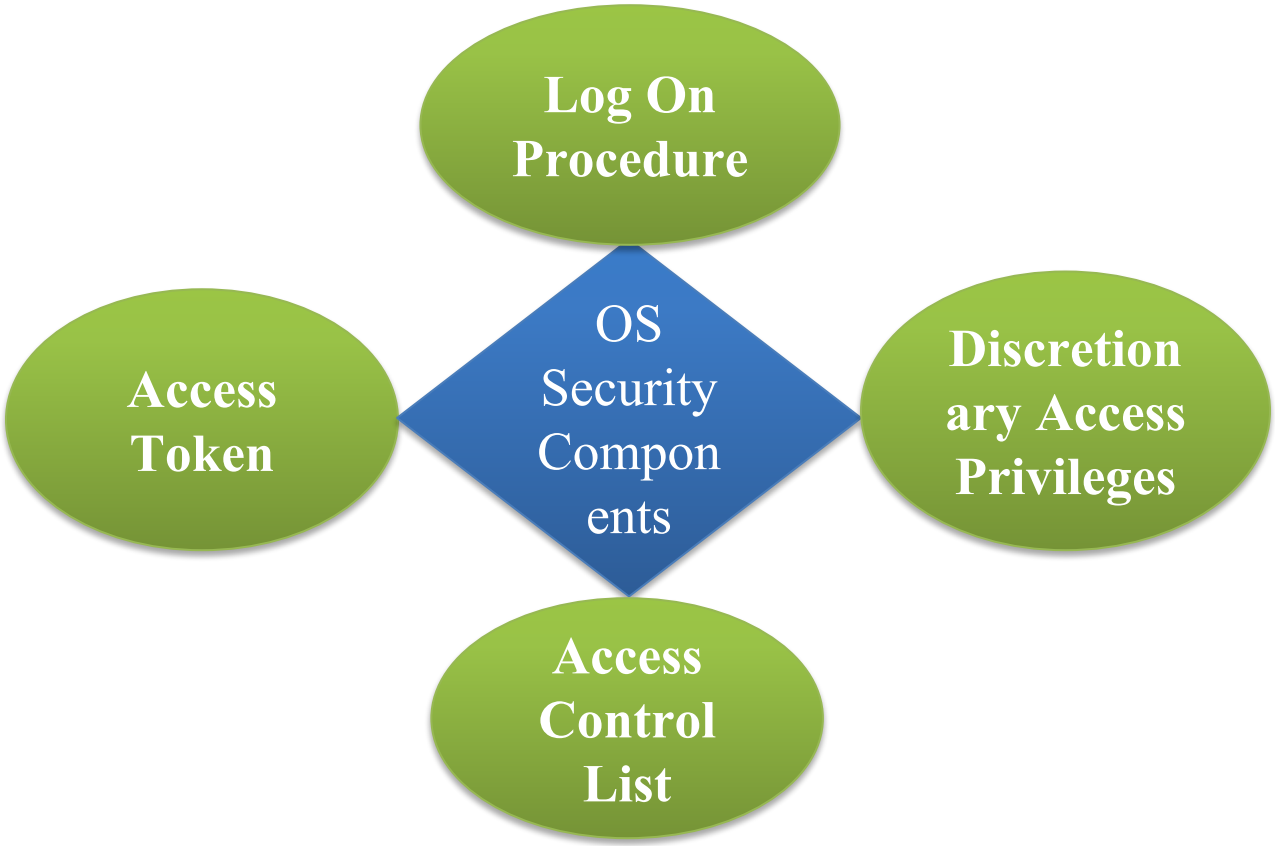
2. The operating system must protect users from each other. One user must not be able to access, destroy, or corrupt the data or programs of another user.

3. The operating system must protect users from themselves. A user's application may consist of several modules stored in separate memory locations, each with its own data. One module must not be allowed to destroy or corrupt another module.

4. The operating system must be protected from itself. The operating system is also made up of individual modules. No module should be allowed to destroy or corrupt another module.
5. The operating system must be protected from its environment. In the event of a power failure or other disaster, the operating system should be able to achieve a con trolled termination of activities from which it can later recover

Operating System Security

Operating system security involves policies, procedures, and controls that determine who can access the operating system, which resources (files, programs, printers) they can use, and what actions they can take.



Operating System Security Components

Operating system security components:

❑ Log on procedure:

A formal log-on procedure is the operating system's first defense against unauthorized access. It requires users to enter a valid user ID and password, which the system verifies against an authorized user database. To enhance security, failed log-on messages should not disclose whether the ID or password is incorrect, and the system should lock the user out after a limited number of unsuccessful attempts.

❑ Access Token:

If the log-on attempt is successful, the operating system creates an access token that contains key information about the user, including user ID, password, user group, and privileges granted to the user. The information in the access token is used to approve all actions the user attempts during the session

Operating System Security Components

❑ Access Control List:

An access control list is assigned to each IT resource (computer directory, data file, pro gram, or printer), which controls access to the resources. These lists contain information that defines the access privileges for all valid users of the resource.

❑ Discretionary action privileges :

In **distributed systems**, discretionary access privileges allow resource owners to grant access rights to other users. Users may receive read-only or read-and-write permissions based on their roles. Since excessive or improper granting of privileges can lead to security breaches, discretionary access control in distributed systems must be closely supervised.

Threats to Operating System Integrity

- **Operating system control objectives may fail** due to accidental or intentional exploitation of system flaws.
- **Accidental threats** include hardware failures and application program errors that cause system crashes.
- Such failures may result in **memory dumps to disks or printers**, leading to unintentional disclosure of confidential data.
- **Intentional threats** mainly involve illegal access to data, privacy violations, or system damage.

- **Sources of intentional threats include**:

✔ **Privileged personnel** (e.g., system administrators or programmers) who abuse their authorized access.

✔ **Internal or external attackers** who search for and exploit operating system vulnerabilities.

✔ **Insertion of viruses or destructive programs**, either deliberately or accidentally.

OS Controls and Audit Tests

Controlling Access Privileges

User access privileges define which system resources individuals or workgroups may access and the actions they are permitted to perform. These privileges are assigned by the system administrator or resource owner and must align with users' job responsibilities. Granting incompatible access rights can weaken segregation of duties and compromise system security. Therefore, access privileges should be carefully administered and continuously monitored to ensure compliance with organizational policies and internal control principles.

Audit Objectives Relating to Access Privileges

The auditor's objective is to verify that access privileges are granted in a manner that is consistent with the need to separate incompatible functions and is in accordance with the organization's policy

OS Controls and Audit Tests

Audit Procedures Relating to Access Privileges

To achieve their objectives auditors may perform the following tests of controls:

• Review the organization's policies for separating incompatible functions and ensure that they promote reasonable security.
• Review the privileges of a selection of user groups and individuals to determine if their access rights are appropriate for their job descriptions and positions.
• Review personnel records to determine whether privileged employees undergo an adequately intensive security clearance check in compliance with company policy.
• Review employee records to determine whether users have formally acknowledged their responsibility to maintain the confidentiality of company data.
• Review the users' permitted log-on times. Permission should be commensurate with the tasks being performed

OS Controls and Audit Tests

❑ Password Control

A secret code to access systems, applications, data files, or networks.
Access is **denied** if the correct password is not entered. Provides a **first line of defense** against unauthorized access.

▯ The most common forms of contra-security behavior include:

- Forgetting passwords and being locked out of the system.
- Failing to change passwords on a frequent basis.
- The Post-it syndrome, whereby passwords are written down and displayed for others to see.
- Simplistic passwords that a computer criminal easily anticipates.

OS Controls and Audit Tests

Common Password Control Methods

Reusable Password:

Most common method of password control is reusable password. User defines the password once and reuses it for future access security depends on the strength of the password.

Weaknesses of Reusable Passwords

- Personal information–based passwords (name, birth date, pet name) are easy to guess
- Non personal but simple patterns (e.g., A-S-D-F, repeated characters) are easily cracked
- Strong passwords with random letters and digits are more secure but harder to remember

Control Measures for Reusable Passwords

✔ Require regular password changes
✔ Disallow weak passwords
✔ Use software to:
  - Scan password files
  - Notify users of expired passwords
  - Validate new passwords against databases of weak passwords

OS Controls and Audit Tests

Common Password Control Methods

One Time Password:

One-time passwords are designed to overcome the weaknesses of reusable passwords by continuously changing the user's password. This system uses a smart card with an embedded microprocessor that generates a unique password every 60 seconds, synchronized with authentication software on a server or mainframe. To gain access, the user enters a personal identification number (PIN) along with the current password displayed on the card, which can be used only once, thereby preventing reuse even if intercepted. An alternative one-time password method uses a challenge–response approach, where the system issues a challenge code and the smart card generates a corresponding one-time response password that is verified by the network before granting access.

OS Controls and Audit Tests

Malicious and Destructive Programs

Malicious programs cause significant corporate losses through data corruption, system damage, privacy violations, and recovery costs. Common types include viruses, worms, logic bombs, Trojan horses, and back doors. These threats can be significantly reduced through a combination of technical controls and administrative procedures.

Controls Against Malicious Programs

- Purchase software only from reputable vendors and use factory-sealed packages.
- Enforce an organization-wide policy prohibiting unauthorized or pirated software.
- Scan all software upgrades and public-domain software for viruses before use.
- Establish formal procedures for changes to production programs.
- Conduct user awareness training on virus and malware threats.
- Test all new applications on a stand-alone system before deploying to servers or networks.
- Perform regular backups of critical files and systems.
- Restrict users to read and execute privileges wherever possible.
- Require users to explicitly invoke the operating system log-on procedure (e.g., CTRL + ALT + DEL) to avoid Trojan horses.
- Use antiviral (vaccine) software to detect and remove known viruses on mainframes, servers, and PCs.

OS Controls and Audit Tests

Audit Objective Relating to Viruses and Other Destructive Programs

The key to computer virus control is prevention through strict adherence to organizational policies and procedures that guard against virus infection. The auditor's objective is to verify that effective management policies and procedures are in place to prevent the introduction and spread of destructive programs, including viruses, worms, back doors, logic bombs, and Trojan horses.

Audit Procedures Relating to Viruses and Other Destructive Programs

- Through interviews, determine that operations personnel have been educated about computer viruses and are aware of the risky computing practices that can introduce and spread viruses and other malicious programs.
- Verify that new software is tested on standalone workstations prior to being implemented on the host or network server.
- Verify that the current version of antiviral software is installed on the server and that upgrades are regularly downloaded to workstations.

OS Controls and Audit Tests

System Audit Trail Controls

System audit trails are logs that record activity at the system, application, and user level. Operating systems allow management to select the level of auditing to be recorded in the log. Audit trails typically consist of two types of audit logs**: (1) detailed logs of individual keystrokes and (2) event-oriented logs.**

Keystroke Monitoring

Keystroke monitoring involves recording both the user's keystrokes and the system's responses. This form of log may be used after the fact to reconstruct the details of an event or as a real-time control to prevent unauthorized intrusion. Keystroke monitoring is the computer equivalent of a telephone wiretap. Whereas some situations may justify this level of surveillance, keystroke monitoring may also be regarded as a violation of privacy. Before implementing this type of control, management and auditors should consider the possible legal, ethical, and behavioral implications.

Event Monitoring

Event monitoring summarizes key activities related to system re sources. Event logs typically record the IDs of all users accessing the system; the time and duration of a user's session; programs that were executed during a session; and the files, databases, printers, and other resources accessed.

Audit Trail Objectives

- **Audit trails support security and control in three main ways:**

1. Detecting Unauthorized Access

- ✔ Audit logs help detect unauthorized system access either in real time or after the event.
- ✔ Real-time detection protects systems from active threats like hackers, viruses, or worms but may increase system overhead.
- ✔ After-the-fact logs are reviewed later to determine whether unauthorized access attempts occurred or succeeded.

2. Reconstructing Events

- ✔ Audit trails help investigators trace the sequence of actions that led to system failures or security violations.
- ✔ This helps identify causes, assign responsibility, and prevent similar incidents in the future.

Audit Trail Objectives

3. **Personal Accountability**

- ✔ Audit logs track detailed user activities, discouraging misuse because users know their actions are recorded.
- ✔ They also help detect abuse of authority and policy violations by linking actions to specific individuals.

Auditing Networks

- **Computer Network:** Computer network connects two or more devices to facilitate resource, information sharing among them.

- Business networks improve communication and resource sharing but increase the risk of unauthorized access to sensitive data. As organizations depend on LANs and Internet connections, they become vulnerable to hackers and dishonest insiders. The main challenge is balancing user access with strong security controls

- **Networking Paradox:** Networks exist to provide user access to shared resources, yet the most important objective of any network is to control such access.

Computer Network Risks

- **Intranet risks:** Intranet risks posed by dishonest employees who have the technical knowledge and position to perpetrate frauds.

Intranets connect employees across buildings and locations using LANs and WANs to support activities like email, transactions, and Internet access. These networks face internal threats mainly from dishonest current or former employees. Such individuals may misuse their technical knowledge and access for revenge, fraud, or selling confidential data. Sensitive information like trade secrets, operational, and accounting data is especially at risk.

Computer Network Risks

Different types of intranet risks:

Interception of Network Messages

Network messages on intranets travel through shared channels and may include sensitive data like user IDs, passwords, emails, and financial files. Unauthorized interception of this data is called sniffing. While administrators use sniffer tools for monitoring and troubleshooting, attackers can also use them to capture confidential information. The risk becomes even higher when the intranet is connected to the Internet.

Access to Corporate Databases

When intranets are linked to central corporate databases, employees with access can misuse data by viewing, altering, copying, or selling sensitive information. This includes customer data, financial records, and proprietary designs or formulas. Insider threats may also involve bribery to manipulate accounts or erase liabilities. Such internal fraud and corporate espionage can cause very large financial losses each year.

Computer Network Risks

- **Internet risks:** Internet risks that threaten both consumers and business entities.

IP Spoofing:

IP spoofing is a technique where an attacker disguises their identity by modifying their IP address to appear as a trusted source. This allows malicious messages or packets to bypass security controls and gain unauthorized access to systems. Attackers use it to commit fraud, espionage, or data destruction. For example, a fake order may appear to come from a legitimate customer, causing financial loss to a company.

Denial of Service Attack

A denial-of-service (DoS) attack targets a web server to make it unavailable to legitimate users. It disrupts normal operations and can severely affect businesses by blocking customer transactions and services. These attacks overload systems with malicious traffic or requests. Common types include SYN flood, smurf attacks, and distributed denial-of-service (DDoS).

Computer Network Risks

Different types of internet risks:

SYN Flood Attack

A **SYN flood attack** is a type of DoS attack that exploits the TCP/IP three-way handshake process. Normally, a client sends a SYN request, the server replies with SYN-ACK, and the client completes the connection with an ACK. In a SYN flood, the attacker sends many SYN requests but never sends the final ACK. This leaves the server with many half-open connections that fill up its ports and block legitimate users. These attacks are hard to stop because attackers often hide their identity using IP spoofing.

Smurf attack

A **smurf attack** is a DoS attack that uses three parties: the attacker, an intermediary network, and the victim. The attacker sends spoofed ping requests using the victim's IP address to a network's broadcast address, causing all computers in that network to reply at once. These mass echo replies flood the victim's system and overwhelm it with traffic. The intermediary network is unaware and also suffers congestion. Disabling broadcast addressing at firewalls can help reduce smurf attacks.

Computer Network Risks

- **Different types of internet risks:**

- **Distributed denial of service(DDos):**

A **distributed denial-of-service (DDoS)** attack is a large-scale DoS attack launched using many compromised computers called bots or zombies. Attackers infect these machines—often through insecure networks or malicious programs—and control them as a botnet to flood a target with traffic. Because the attack comes from thousands of different systems, it is much more powerful and harder to trace or block than a single-source attack. This makes DDoS attacks especially dangerous and difficult to stop.

Controlling Network

❑ Controlling risks from subversive threats:

- **Firewalls:** A **firewall** is a system that enforces **access control between two networks** (e.g., Internet and organizational intranet).

❖ Basic Firewall Rules

- ✔ All traffic between internal and external networks must pass through the firewall.
- ✔ Only traffic authorized by the organization's security policy is allowed.
- ✔ The firewall must be protected from penetration from both outside and inside the organization.

Controlling Network

❑ Controlling risks from subversive threats:

▯ Firewalls

❖ Network-Level Firewalls

- ✔ Use screening routers to examine source and destination addresses.
- ✔ Apply filtering rules to allow or deny traffic.
- ✔ Efficient and fast.
- ✔ Lower security.
- ✔ Do not explicitly authenticate users.
- ✔ Designed to allow freer flow of information.

❖ Application-Level Firewalls

- ✔ Provide higher, customizable security.
- ✔ Use proxy applications.
- ✔ Authenticate users for specific tasks.
- ✔ Offer detailed logging and auditing.
- ✔ Slower due to added processing overhead

Controlling Network

- **Controlling risks from subversive threats:**
- **Controlling Denial of Service Attacks**

General Controls for Denial of Service (DoS) Attacks):

- ✔ **Strong Firewall Rules**: Filter all incoming and outgoing traffic, block suspicious sources.
- ✔ **Traffic Monitoring**: Continuously monitor network activity for abnormal patterns.
- ✔ **Connection Management**: Detect and clear half-open or inactive connections.
- ✔ **Intrusion Prevention System (IPS)** : Automatically detect and block malicious traffic.
- ✔ **Deep Packet Inspection (DPI)**: Examine packet headers and payloads to identify attacks.
- ✔ **Outbound Traffic Filtering**: Prevent IP spoofing and botnet participation.
- ✔ **Layered Security**: Use firewall + IPS + monitoring for stronger protection.

Controlling Network

❑ Controlling risks from subversive threats:

▯ Encryption

Encryption is the process of converting data into a coded form to protect it from unauthorized access during storage or transmission. The original readable data, known as cleartext, is transformed into an unreadable format called ciphertext using a mathematical algorithm and a secret key. Only authorized parties who possess the correct key can decrypt the ciphertext back into its original form. Encryption ensures confidentiality, protects sensitive information, and is a fundamental security mechanism used in databases, communication networks, and digital systems.

Reference

[1] James A. Hall: *Information Technology Auditing* & Assurance, Third Edition

THANK YOU